

Authentication



Chapter 3



Authentication

— — —

★ Definition

★ Authentication Methods

- What do you know?
- What do you have?
- What do you trust?

★ Authentication Protocol

★ Zero-Knowledge Password Proof

★ Good Password and Bad Password

★ Password Hacking

- Rainbow Table

★ Implementation Issues



Definition of Authentication

“It’s easy to know men's faces, not their hearts.”
Chinese Proverb

★ In a computer system, authentication is the **process of verifying identity of a user.**

In a communication system, authentication is the process of verifying the stated source of a message [dictionary.com].

- validating the quality or condition of being trustworthy, genuine, or creditable
- examination of a token or investigation of some property of the subject itself



How to Authenticate?

— — —

- ★ Validating authenticity of a document (e.g. transcript, bank note, cheque)
- ★ Identifying a person (student, member of a group, ...)
- ★ The source of data (e.g. network packet, email, ...)
- ★ Owner of (house, car, ...)
- ★ How about software or computer systems?



Authentication Methods

- ★ What do you know? *ความรู้*
- ★ What do you have? *สิ่งของ*
- ★ Who do you trust? *คนที่เชื่อถือ*



- ★ Every authentication method has its own strength and weakness, and there is no such thing as a perfect authentication method.





What do you know?

A secret between two is God's secret, a secret between three is everybody's.
Spanish Proverb

- ★ Prearrange questions *အတူတူသိသောမေးခွန်းများ*
- ★ Password or Passphrase
- ★ One-time pad : Password *အတိုင်းအတာမရှိသော, Highest security Password*
- ★ Challenge and Response
 - How much is $1+1$?

In the past, an american soldier has to state a prearrange question with the army for identifying himself in case of emergency.



Challenge and Response

↳ input N into lock

- ★ Knowledge of a method
 - ★ Alice $\rightarrow$ Bob : N
 - ★ Bob $\rightarrow$ Alice: $\{N, B\}^k$
 - ★ Prevent replay attacks in freq. infra lock
-
- ★ To avoid replay attack, car remote is now a challenge and response.





What do you have?

Japan *Shōnin* Stamp 11hu ms/74

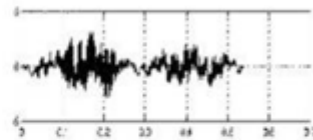
★ Tokens

- ID
- Seal

★ Smart Tokens

★ Biometrics

- Fingerprints
- Hand/Palm geometry
- Handwriting
- Face Recognition
- Dental biometrics
- Retinal
- Vein
- Voice
- Pattern (walking/typing rhythms)



John Smith



What do you trust?

★ Third party authentication

- Facebook Login
- Google Login
- ChulaSSO

★ Proximity/Trusted Zone *Simulation*

- Dress like a student on the campus





Authentication Protocol

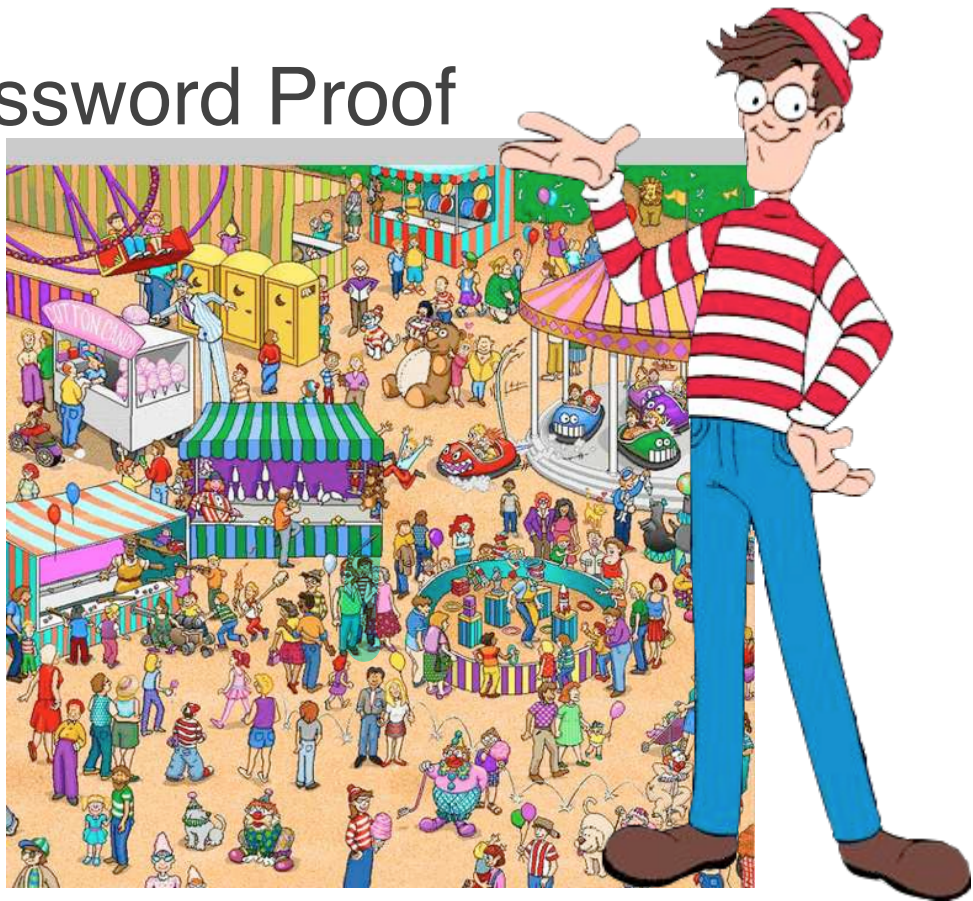
- ★ A combination of methods for authentications
- ★ Use a combination of password and smart tokens
- ★ Example
 - Login with SSH to a gateway
 - Server challenges with a nonce
 - Use crypto card to generate a one-time password
 - Use it to access the system.





Zero-Knowledge-Password Proof

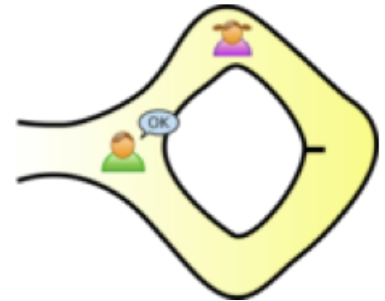
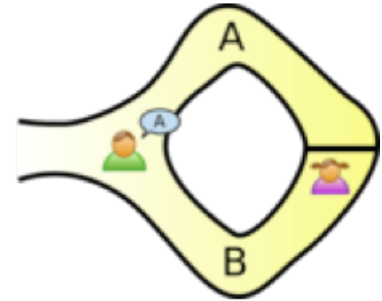
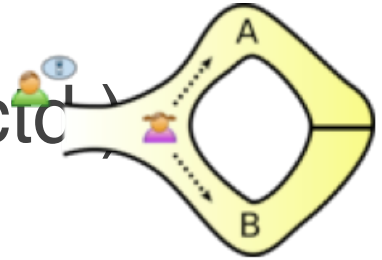
- ★ An authentication protocol.
- ★ Proof the knowledge of password without saying it out loud.
- ★ Where is Waldo?
- ★ Both parties share a same picture. Use a coordinate of Waldo to validate the knowledge.
- ★ Modern authentications are based on ZKPP.





Zero-Knowledge-Password Proof (ctc)

- ★ Proof that the little girl got a key to the gate at the end of the tunnel.
- ★ Let the girl walk into the tunnel.
- ★ Ask her to get out at a random direction.
- ★ Repeat the steps several time.
- ★ If that girl always come out at the right direction, she got a key.





Password Security

— — —

We still rely on Username/Password, but how strong is it?



Good Password and Bad Password

— — —

★ Substitution (Good?)

- act10n
- 0wn3r
- 4U&m3
- p3nc1l

★ Guessable pattern (Bad?)

- Qwerty
- Q1w2e3r4t5y
- Password1
- Password2



How does a password get stored?

A brief History

- The beginning - **Plaintext** (1960s)
 - @MIT (1961), A programmer accidentally printed the password file to a shared printer. Can we do better?
- The First Leap - **Hashing** (Early 1970s)
 - One-way function, deterministic ? *one-way function*
- The attacker's response - **Salted Hashing** (1980s+)
 - We will try this in the activity. *→ combination of salt and password*
- Modern Day - Slow, Adaptive Hashing (2000s+)
 - Bcrypt, Scrypt, Argon2 *→ Hash function design for password storage:*
 - Slow, memory intensive, expensive, even with powerful hardware *compute time*



How secure is a password?

— — —

★ Assume that:

- n is the length of the password (e.g. digits or characters).
- k is the number of characters in the set of possible characters.
- C is the constant amount of time requires for testing a password (e.g. seconds).
- t is the number of times allowed to guess the password before locking the account.

★ Given n characters in a password, each character is taken from the k characters in the set,

How long will it take to test all possibilities?



Password Hacking

- ★ Dictionary attack : *ใช้ dictionary กับ hash function → เมื่อ match*
- ★ Brute-force attack : *every possible*
- ★ Rainbow table : *memory, map (hash, string) rainbow-table, lookup table*
- ★ Replay attack
- ★ Social Engineering (Phishing)

*→ ใช้ dictionary hash
ใช้ dictionary*



Watch this

<https://www.youtube.com/watch?v=6bNtMPKafk0>

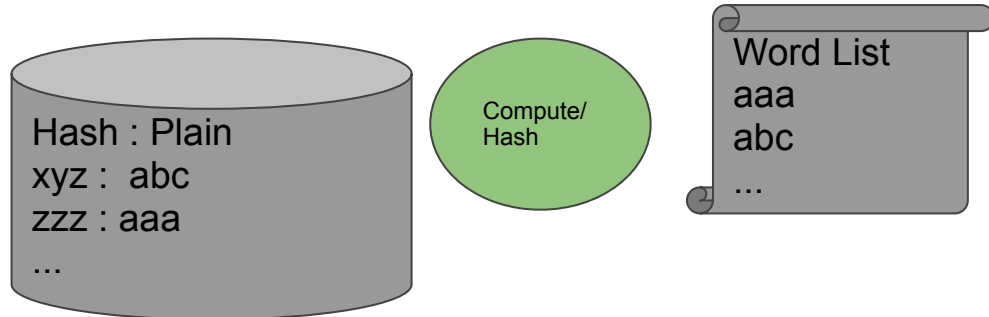
<https://www.youtube.com/watch?v=f-Dogvyn9ZU>



Rainbow Table

- ★ Password is based on one-way hash function. (Theoretically, irreversible).
- ★ Rainbow Table is the use of idle processing power to **precompute possible** results.
- ★ **Change from trying to looking up from the table.**
(Instant result)

Obtain a hashed value xyz.
Look up for xyz -> **abc**





Fact

Rainbow Table

- free download
- (Was) indexed by Search Engine

- ★ Try search hashed values of simple words in google.

```
$ echo "security" lmd5
```

```
e46d69abde01f581f79cd4ec029a8469
```

```
echo "online" lmd5
```

```
747a43298e195448246825207a9364b6
```

- ★ Rainbow Table can be downloaded for free.
(<http://project-rainbowcrack.com/table.htm>)

- ★ Try it with your password.
If it is in the rainbow table, change your password.

— — —



Defensive Measures & Best Practices

— — —

- Multi-Factor Authentication
 - SMS?, Authenticator Apps?
- Password Policies
 - Combination of uppercase letters, lowercase letters, numbers, symbols
- Rate Limiting and Account Lockouts
 - See fail2ban
- Human Factor
 - Password Managers



Implementation Issues

— — —

★ Issues not covered in this slide

- Management Cost
- Communication Channel
- Human Factor/Social Engineering
- Accuracy *Highest risk*
- Transferability
- Centralize vs. Distributed
- Single Sign-On



End of Chapter 3